

Product Requirements Document — Safe AI Automation for MSP Operations

Concept: *The Trust Ladder* — a trust-and-control layer for introducing AI agents into MSP production environments safely. **Author:** Munshi Javed Akhtar **Status:** Concept prototype · **Version:** 1.0 **Companion artifacts:** interactive prototype (prototype/index.html), one-page briefing (One-Page-Briefing.pdf)

1. Executive summary

MSPs are drowning in repetitive Level 1/2 operational work and want AI agents to absorb it. But an agent that can *act* on a client's production estate — isolate an endpoint, restore a backup, restart a service — is also an agent that can *break* it. The blocker to adoption is not capability; it is **trust, oversight, and accountability**. An MSP owner will not flip an agent to "autonomous" when their client's uptime and their own liability are on the line.

Typical MSP workflow *builders* define **what** an agent does. This PRD specifies the layer around them that decides **whether an agent is trusted to act, who may authorise it, and how the MSP proves what happened afterwards**.

The core model is a **Trust Ladder**: an agent is never simply "on" or "off." It climbs earned rungs of autonomy — Shadow → Suggest → Approve-to-act → Auto+notify — and only rises as evidence accumulates that it agrees with human technicians. Five product surfaces make this real: safe activation, an oversight inbox, an execution & audit trail, a reliability & evals loop, and role-based access control.

The illustrating workflow is deliberately high-stakes: **ransomware detected → isolate the endpoint and restore from a clean backup**, driven by two agents (Triage → Remediation) with a human checkpoint between classification and any destructive action.

2. Problem statement

2.1 Who has the problem — personas

- **Sofia — MSP Owner / Service-Delivery Manager (the buyer)**. Runs a 40-person MSP serving ~120 SMB clients. Carries every client SLA and the liability when something breaks. Wants automation to cut Level 1/2 labour cost and improve response time — but *one* cascading mistake across a multi-tenant estate could end a contract, so she will not adopt on faith. **Decides whether AI is turned on at all.**
- **Arjun — Automation Admin / Lead Engineer (the configurer)**. Owns the agents day to day: sets scope, guardrails, and autonomy rungs, and promotes agents when the evidence justifies it. Technical, but doesn't want to babysit prompts — he wants deterministic, testable guardrails he can defend to Sofia.
- **Mia — L2 Technician (the operator)**. Lives in the ConnectWise queue, juggling 50+ networks and hundreds of alerts. Supervises the agents in real time. Needs fast, scannable reasoning so she can approve or reject in seconds — and must *not* be pushed to rubber-stamp for a savings number.
- **David — Compliance / vCISO / Auditor (the accountability owner)**. Must defend every automated action to a client or a regulator (SOC 2 / ISO 27001 / HIPAA). Needs a tamper-evident, exportable record of *what happened, why, and on whose authority* — read-only, but complete.

2.2 The core pains

1. **Activation freeze.** Teams see the value of automation but won't turn it on, because a single wrong action in a multi-tenant environment can cascade across clients, cause downtime or data loss, and end a contract. Fear of the *irreversible mistake* outweighs the efficiency upside.
2. **Black-box anxiety.** When an agent proposes an action, technicians can't see *why*. Approving blind is just moving the risk, not reducing it — so they reject automation or rubber-stamp it, both bad.
3. **No defensible record.** After an incident, "the AI did it" is not an acceptable answer to a client or an auditor. Teams need to show what happened, why, on whose authority, and whether it can be undone.
4. **One-size-fits-all access.** Prototypes assume a single all-powerful user. In reality, giving a junior technician the same power as the owner (global kill switch, cost dashboards, guardrail editing) is itself a safety and governance failure.

2.3 Why now

LLM-based agents are finally capable enough to triage and remediate real operational tickets. The bottleneck has shifted from *can the agent do it* to *can we trust it in production*. Whoever solves the trust layer — not the capability — wins MSP adoption.

2.4 User stories

- As **Sofia (Owner)**, I want to prove an agent's accuracy against 90 days of my own historical incidents *before* it can act, so I can adopt automation without betting a client contract on a promise.
- As **Sofia (Owner)**, I want autonomy promoted per-agent only on evidence (and demoted automatically on drift), so trust is earned and reversible rather than a one-way switch.
- As **Arjun (Admin)**, I want guardrails enforced by the platform — not by the prompt — so a mis-reasoning model is *physically* unable to isolate a domain controller or run a destructive command.
- As **Mia (Technician)**, I want each proposed action to show its reasoning, evidence, calibrated confidence, and per-guardrail result, so I can approve or reject in seconds instead of rubber-stamping blind.
- As **Mia (Technician)**, I want a scoped pause on a misbehaving agent without seeing €-ROI targets, so I'm never pressured to approve for savings.
- As **David (Auditor)**, I want a tamper-evident, exportable record of every action — including the Triage→Remediation hand-off and the human authoriser — so I can defend it to a client or regulator.

2.5 Stakeholders & audience (*not users, but their requirements shape the design*)

Beyond the four user personas, this platform must satisfy **internal security, engineering, ML, and UX gatekeepers** before it ships:

- **Platform Security / EDR Architecture** — requires hard multi-tenant isolation, deterministic (non-AI) policy enforcement, and a tamper-evident audit trail before certifying any AI capability. (*Addressed in §8 and the Backend Architecture doc §9.*)
- **Backup / Kernel Engineering** — must expose a fast pre-action snapshot (VSS / volume) hook so every destructive action is reversible. (§6.3, *Architecture* §5.)
- **Data Science / ML** — owns the models and the eval golden set the trust loop depends on. (§6.4.)
- **UX** — owns the activation flow and oversight inbox that make the safety model legible.

(These are stakeholders whose requirements are dependencies, not personas who operate the product — kept distinct on purpose.)

3. Goals & non-goals

3.1 Goals

- Let an MSP move an agent from zero to production **incrementally and reversibly**, with confidence at each step.
- Keep a **human in the loop without making the human a bottleneck**.
- Make every automated action **explainable, attributable, and undoable**.
- Enforce **who-can-do-what** as a first-class safety control.
- Turn every human correction into **measurable improvement** of the agent.

3.2 Non-goals (for this version)

- Building the workflow canvas/builder itself (already exists; this layer wraps it).
 - Training or fine-tuning the underlying models (assumed upstream).
 - A general no-code agent marketplace.
 - Two-person approval quorum and cross-workflow blast-radius budgets — identified as fast-follows (§10).
-

4. Design principles

1. **Trust is earned in rungs, not granted in a switch.** Autonomy is a dial that rises with evidence and falls on drift.
2. **Guardrails are enforced by the platform, not the model.** A mis-reasoning agent must be *physically* unable to cross a hard limit — never relying on the prompt to behave.
3. **Reversibility is the price of automation.** A destructive action ships only when it can be undone.
4. **Show the work.** Fast, safe approvals come from seeing the agent's reasoning and evidence — not from a bare "approve" button.
5. **Separation of duties.** The right person holds each control; the wrong person can't reach it.
6. **Close the loop.** Rejections and divergences become labelled evals, so the system gets safer with use.

5. Illustrating workflow: Ransomware → Isolate & Restore

5.1 Why this workflow

It is destructive, time-critical, and sits exactly where cyber-protection and backup platforms differentiate — it needs both **cyber protection** (detect + isolate) and **backup** (find a clean, verified restore point). If the trust model holds for this, it holds for gentler workflows.

5.2 The two agents (multi-agent orchestration)

- **Triage Agent** — on an EDR alert, confirms whether it's genuinely ransomware (encryption rate, ransom note, known family), assesses the endpoint's criticality, and locates the most recent **clean, integrity-verified backup that predates the infection**. Outputs a classification: true positive → hand off; ambiguous → route to a human; false positive → close.
- **Remediation Agent** — receives a true-positive packet and prepares two actions: **isolate** the endpoint (stop lateral spread) and **restore** from the clean backup. Checks guardrails, then waits for human approval (at the Approve-to-act rung).

The **human checkpoint sits between classification and any destructive action** — this is the safety-critical seam.

5.3 Why it beats a human at 3am

- **Speed:** ransomware spreads in minutes; the agent compresses 15–40 min of human investigation to seconds, so the human starts at “approve?” not “what’s happening?”
- **Always-on:** one technician can’t watch 50 clients’ endpoints overnight — exactly when attacks fire.
- **Removes error-prone glue work, not judgment:** consistently verifies that a backup isn’t itself encrypted — the step a tired human gets wrong — while the human keeps the irreversible call.
- **Scales MSP economics:** 24/7 response without night staffing.

6. Product surfaces & functional requirements

6.1 Safe activation (5-step flow)

A destructive agent cannot go from off to autonomous in one click. The flow forces evidence of safety first.

#	Step	Requirement
1	Scope	Select tenant(s), trigger, and active window. Scope is a hard containment boundary — blast radius can never exceed it.
2	Guardrails	Configure platform-enforced hard limits (e.g. never isolate role:critical-infra, require verified clean backup <24h, all actions reversible, rate limits). Includes a live script-safety linter that blocks any command outside the certified allow-list (e.g. Remove-Item, Format-Volume).
3	Dry-run	Replay the agent over 90 days of the tenant’s real historical incidents. Report agreement %, escalations, and divergences with proposed new guardrails. This is the primary trust-building moment: proof, not promises.
4	Autonomy rung	Choose starting rung (Shadow / Suggest / Approve-to-act / Auto+notify). Destructive workflows default to a low rung. Promotion is restricted to Admin/Owner.
5	Canary	Go live on a limited window with mandatory post-action human feedback; auto-pause if agreement drops below threshold.

6.2 Oversight inbox

- Each pending action shows: proposed action, **calibrated confidence**, full **reasoning**, **evidence used**, and **per-guardrail pass/fail**.
- One-click approve / reject / escalate. **Rejections capture a reason** that feeds evals.
- **Time-boxed:** an unactioned live threat escalates to on-call + PSA within a set window — it is never silently dropped.
- Surfaces both agents: a Remediation action *and* a Triage decision (including the agent choosing **not** to escalate an ambiguous alert to a destructive action).

6.3 Execution & audit trail

- Every run is a **tamper-evident, exportable** record answering: what did it do, why, on whose authority, was it reversible.
- Shows the **Triage → Remediation handoff** explicitly (auditable multi-agent orchestration).
- **One-click rollback** — every action is captured as a reversible transaction with a pre-action snapshot.
- Records model + prompt version, guardrails enforced, data accessed, and a signed integrity hash.

6.4 Reliability & evals

- **Human-agreement rate** tracked over time against a promote threshold (e.g. 95%).
- **Drift/anomaly alerts** (e.g. confidence decay on a step) with automatic escalation behaviour.
- **Eval suite** gating every prompt/model change before production: golden-set accuracy, destructive-action safety, prompt-injection resistance.
- **Closed loop:** inbox rejections and dry-run divergences become new labelled eval cases.

6.5 Role-based access control (RBAC)

Separation of duties, enforced in the UI and API.

Capability	Owner	Admin	Technician	Auditor
€-denominated ROI view	✓	✓	✗ (sees accuracy instead)	✗
Kill switch	Global	Global	Scoped (single agent)	—
Edit guardrails / activate	View	✓	✗	✗
Promote autonomy rung	✓	✓	✗	✗
Approve / reject actions	Read-only	✓	✓	✗
Rollback	✓	✓	✗	✗
Export audit record	✓	✓	✗	✓

Design rationale: showing cost figures to a front-line technician pressures them to approve for savings, undermining oversight — so technicians see **accuracy**, not money. A global kill switch in every junior’s hands is an availability risk — so technicians get a **scoped** pause only.

7. Autonomy model (the Trust Ladder)

Rung	Name	Agent behaviour	Human role
L0	Shadow	Decides silently; nothing acts	Compare decisions vs reality
L1	Suggest	Drafts the action in the queue	Human executes everything
L2	Approve-to-act	Prepares action, waits for approval	One-click approve/reject
L3	Auto + notify	Acts within guardrails, notifies	Review after the fact; can roll back

Movement between rungs is **evidence-gated** (agreement ≥ threshold, zero guardrail breaches over a window) and **permission-gated** (Admin/Owner only). Drift automatically demotes or pauses.

8. Trust, safety & compliance

- **Guardrails enforced at the platform layer** — independent of model output.
- **Prompt-injection defence** — instructions embedded in ticket/user content are treated as data, never commands.
- **Multi-tenant isolation** — scope boundaries prevent cross-tenant action.
- **Full attribution & audit** — every action tied to an agent version, prompt version, and human authoriser; exportable for SOC 2 / ISO 27001 / HIPAA contexts.
- **Reversibility by default** for destructive actions.

9. Success metrics

Adoption / activation - % of eligible workflows activated past Shadow rung. - Time from activation to first Approve-to-act rung (target: down over time).

Trust / quality - Human-agreement rate (target $\geq 95\%$ before promotion). - Guardrail-breach count (target: 0).

Efficiency / value (*the metrics an MSP buyer benchmarks on*) - **MTTR — mean time to respond/remediate** for the ransomware workflow (target: minutes, not tens of minutes). The agent compresses the investigate-and-prepare phase so a human starts at "approve?", not "what's happening?". - **MTTD — mean time to detect/triage** (alert → confirmed classification). - Technician hours saved / month; €-value (Owner/Admin view). - Approval median time (target: seconds).

Reliability - Eval-suite pass rate on every release. - Drift alerts caught before client impact.

10. Rollout & fast-follows

- **Phase 1 (this concept):** single high-stakes workflow, all five surfaces, RBAC, dry-run + canary.
 - **Phase 2:** additional workflows (patch remediation, disk cleanup, VSS restart, phishing triage) reusing the same trust layer.
 - **Phase 3 (fast-follows):**
 - Two-person approval quorum for the highest-risk actions.
 - Cross-workflow blast-radius budgets (cap total automated impact per tenant per window).
 - Partner-facing shared eval library across the MSP base (anonymised).
-

11. Open questions

- What is the right default agreement threshold per risk tier, and should it be MSP-configurable?
 - Should the canary auto-pause notify the client, or only the MSP?
 - How much of the audit trail should be exposed directly to the end client vs. the MSP only?
 - Where does human accountability legally sit when an agent acts at L3 — the approver, the admin who promoted it, or the MSP?
-

Companion artifacts: interactive prototype (<prototype/index.html>) and one-page briefing (with AI-tools & process disclosure).